

SameSite Strict bypass via client-side redirect

Category: CSRF / SameSite Cookie Bypass

Platform: PortSwigger Web Security Academy

Difficulty: Practitioner

Tool: Burp Suite

Objective

Exploit a client-side redirect to bypass CSRF protection provided by the `SameSite=Strict` cookie attribute.

Vulnerability

`SameSite=Strict` normally prevents cookies from being sent with cross-site requests. However, a client-side redirect can change the navigation context before the sensitive request is made. If the application contains a controllable redirect mechanism, this behavior can potentially be abused to reach a protected endpoint with the victim's authenticated cookies.

Methodology

1. Identified the sensitive endpoint protected by `SameSite=Strict`.
2. Examined the application for client-side redirect functionality.
3. Found a redirect mechanism that could be influenced by an attacker.
4. Crafted a malicious request that triggered the client-side redirect.
5. Observed that the browser subsequently accessed the sensitive endpoint in a context where the authentication cookie was available.
6. Confirmed successful execution of the protected action.

Impact

An attacker may bypass the intended SameSite protection and cause an authenticated victim to perform an unwanted action.

Remediation

SameSite cookies should be treated as an additional security layer rather than the sole CSRF defense. Sensitive state-changing requests should also require strong, session-bound CSRF tokens and appropriate Origin/Referer validation.

References

- PortSwigger Web Security Academy – CSRF
- OWASP – Cross-Site Request Forgery Prevention